

# **SIMATS ENGINEERING**

## **ASSESSMENT TOOL 1**

**COURSE CODE: CSA5113**

**COURSE NAME: Cryptography and Network Security**

### **COURSE OUTCOME COVERED**

**CO5:** *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 40%

**QUESTIONS: 5 TOTAL MARKS: 50 Annexure A**

**CONSTRAINT-BASED PROBLEM SOLVING**

### ***Code of Conduct:***

*I DINDU PUJITHA (192373037) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

***Signature of the student: D PUJITHA***

## **Annexure A**

### **CONSTRAINT-BASED PROBLEM SOLVING**

**1. A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.**

#### **Constraints:**

- A. Backward compatibility must be maintained for 20% legacy clients**
- B. Sensitive data must not be transmitted using SSL**
- C. System downtime must be minimal during migration**
- D. Cost of implementation should be optimized**

#### **Answer:**

##### **Secure TLS Migration for Legacy SSL Systems**

The financial institution must migrate to modern TLS while preserving compatibility for approximately 20% legacy clients. The safest design is a staged migration using a TLS termination gateway or reverse proxy that isolates legacy SSL traffic from sensitive application services.

#### **A. Backward Compatibility**

- Deploy a reverse proxy or TLS gateway in front of the web applications.
- Allow legacy SSL only on a dedicated compatibility endpoint.
- Restrict legacy clients to non-sensitive functions wherever possible.
- Monitor usage of the legacy endpoint and gradually retire it.

## **B. Protect Sensitive Data**

- Do not allow sensitive transactions such as account changes, authentication, or financial transfers over SSL.
- Require TLS 1.2 or TLS 1.3 for all sensitive operations.
- Redirect legacy clients to an upgrade page when they attempt sensitive actions.

## **C. Minimal Downtime**

- Use load balancers to introduce the TLS gateway without replacing application servers.
- Migrate services in phases.
- Perform configuration changes during low-traffic periods.
- Keep rollback configurations ready.

## **D. Cost Optimization**

- Reuse existing load balancers or web application firewalls if they support TLS.
- Use centralized certificate management.
- Retire the legacy SSL endpoint after client migration.

## **Architecture**

Legacy Clients → Compatibility SSL Gateway (limited services) → Application Servers.

Modern Clients → TLS 1.2/1.3 Gateway → Application Servers.

## **Conclusion**

A staged TLS migration with a separate legacy compatibility gateway maintains backward compatibility while ensuring that sensitive data is transmitted only through modern TLS.

**2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.**

**Constraints:**

**A. Must support high transaction throughput (10,000 transactions/minute)**

**B. Compatibility with modern browsers is required**

**C. Implementation complexity should be minimized**

**D. Regulatory compliance (PCI-DSS) must be ensured**

**Answer:**

SET Protocol vs TLS for an E-Commerce Platform

The platform processes 10,000 transactions per minute and requires browser compatibility, low complexity, and PCI-DSS compliance. TLS is the more practical solution than SET for this environment.

**Comparison**

| Requirement               | SET          | TLS         |
|---------------------------|--------------|-------------|
| High throughput           | More complex | Efficient   |
| Browser compatibility     | Limited      | Excellent   |
| Implementation complexity | High         | Low         |
| PCI-DSS support           | Possible     | Widely used |
| Modern deployment         | Rare         | Standard    |

### **A. Throughput**

TLS is designed for high-volume web traffic and is optimized by modern browsers, servers, and hardware accelerators.

### **B. Browser Compatibility**

TLS is natively supported by all modern browsers, while SET requires specialized payment infrastructure and is not commonly supported.

### **C. Implementation Complexity**

SET introduces multiple certificates and payment-specific message exchanges, making deployment and maintenance more complex than TLS.

### **D. PCI-DSS Compliance**

TLS 1.2 or TLS 1.3 is widely used in PCI-DSS-compliant payment environments when combined with proper access controls, tokenization, logging, and secure coding practices.

### **Recommendation**

Continue using TLS 1.2/1.3, enforce strong cipher suites, use tokenization for payment card data, and maintain PCI-DSS controls. SET is not recommended for this high-throughput modern browser-based platform.

**3. A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy.**

**Constraints:**

- A. The network consists of 500+ interconnected systems**
- B. Downtime per system should not exceed 10 minutes**
- C. Detection must occur within 2 minutes of infection**
- D. Solution must differentiate between virus, worm, and Trojan behavior**

**Answer:**

**Malware Containment and Prevention Strategy**

The malware spreads without user interaction, indicating worm-like behavior. The response must detect infections within two minutes, isolate affected systems quickly, and distinguish worms from viruses and Trojans.

**A. Immediate Containment**

- Use network access control to quarantine infected endpoints.
- Block suspicious east-west traffic at internal firewalls.
- Segment the network into security zones.
- Isolate infected systems within the required detection window.

**B. Detection Architecture**

- Endpoint Detection and Response (EDR) on all systems.
- Network IDS/IPS for lateral movement.
- Central SIEM for correlation.
- Automated response rules for rapid containment.

### C. Differentiate Malware Types

| Type   | Typical Behavior                                                      |
|--------|-----------------------------------------------------------------------|
| Virus  | Attaches to files and usually needs execution                         |
| Worm   | Self-propagates across networks without user interaction              |
| Trojan | Disguises itself as legitimate software and depends on user execution |

### D. Downtime Constraint

Use automated isolation instead of shutting down entire network segments. Quarantine only affected hosts so that most systems continue operating and the per-system downtime target can be met.

### Prevention

- Rapid patch management.
- Application allowlisting.
- Least-privilege access.
- Network segmentation.
- Regular backups.
- Continuous EDR monitoring.

### Conclusion

An EDR, IDS/IPS, SIEM, and network-segmentation architecture provides rapid worm containment while minimizing downtime and improving prevention.

**4. An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution. Constraints:**

- A. Must support both packet filtering and application-level inspection**
- B. Latency introduced should not exceed 5 ms per request**
- C. Should handle at least 1 Gbps traffic**
- D. Must allow secure remote access for employees**

**Answer:**

### **Firewall Architecture Design**

The firewall must provide both packet filtering and application-level inspection, support at least 1 Gbps, keep latency below 5 ms per request, and provide secure remote access.

#### **Architecture**

Internet → Edge Router → Next-Generation Firewall (NGFW) → DMZ → Internal Firewall → Internal Network. Remote employees connect through a VPN service on the NGFW.

#### **A. Packet Filtering**

The firewall filters traffic using source IP, destination IP, ports, and protocols before deeper inspection.

#### **B. Application Inspection**

The NGFW performs application-aware inspection, intrusion prevention, malware inspection, and URL filtering.



### **C. Performance**

- Select an NGFW rated above 1 Gbps with security services enabled.
- Use hardware acceleration.
- Avoid unnecessary inspection for trusted low-risk traffic where policy permits.

### **D. Secure Remote Access**

Provide IPSec or SSL VPN access with multi-factor authentication, role-based access controls, and centralized logging.

### **Security Zones**

| Zone     | Purpose                      |
|----------|------------------------------|
| Internet | Untrusted traffic            |
| DMZ      | Public web and mail services |
| Internal | Corporate systems            |
| VPN      | Remote employees             |

### **Conclusion**

A layered NGFW and DMZ architecture meets the inspection, throughput, latency, and remote-access requirements while protecting both against external and insider threats.

**5. A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue. Propose an optimized IDS/IPS solution.**

**Constraints:**

- A. Detection accuracy must be at least 95%**
- B. False positive rate should be reduced below 5%**
- C. System must process real-time traffic of 2 Gbps**
- D. Solution should integrate with existing firewall infrastructure**

**Answer:**

**Optimized IDS/IPS Solution**

The enterprise experiences excessive false positives. The solution should improve accuracy to at least 95%, reduce false positives below 5%, process 2 Gbps in real time, and integrate with the existing firewall.

**A. Problems with Current IDS**

- Too many signature-only alerts.
- Outdated rules.
- No contextual correlation.
- Duplicate alerts.
- Limited asset awareness.

**B. Proposed Hybrid IDS/IPS**

Use a combination of signature-based detection, anomaly detection, behavioral analysis, threat intelligence, and SIEM correlation.

**Architecture**

Network Traffic (2 Gbps) → Firewall → IDS/IPS Sensors → SIEM Correlation → Risk Scoring → Automated Response.

### C. Reducing False Positives

- Tune signatures to the organization's environment.
- Suppress duplicate alerts.
- Correlate IDS events with firewall, endpoint, and authentication logs.
- Use asset criticality in risk scoring.
- Whitelist verified business applications carefully.
- Review and update detection rules regularly.

### D. Meeting Constraints

| Constraint              | Solution                                                   |
|-------------------------|------------------------------------------------------------|
| Accuracy $\geq 95\%$    | Hybrid signature + behavioral detection                    |
| False positives $< 5\%$ | Correlation, tuning, and risk scoring                      |
| 2 Gbps traffic          | High-performance sensors and load balancing                |
| Firewall integration    | Share logs and enforce blocking rules through the firewall |

### Automated Response

- Block malicious IP addresses.
- Quarantine compromised endpoints.
- Disable suspicious accounts when policy permits.
- Create high-priority SIEM incidents for analyst review.

### Conclusion

A hybrid IDS/IPS integrated with the existing firewall and SIEM provides higher detection accuracy, substantially reduces alert fatigue, and supports real-time processing of enterprise traffic.

### Overall Recommendations

| Question | Recommended Solution                   |
|----------|----------------------------------------|
| 1        | TLS gateway with phased SSL retirement |

|   |                                                        |
|---|--------------------------------------------------------|
| 2 | TLS 1.2/1.3 with PCI-DSS controls                      |
| 3 | EDR + IDS/IPS + SIEM + network segmentation            |
| 4 | Next-Generation Firewall with DMZ and VPN              |
| 5 | Hybrid IDS/IPS with correlation and automated response |